

## MODULE 3.3: SOCIAL ENGINEERING, SYSTEM HACKING, ENUMERATION, STEGANOGRAPHY

### Contents

|                                              |    |
|----------------------------------------------|----|
| 1. Social Engineering .....                  | 1  |
| Defense Strategies .....                     | 2  |
| 2. Insider Attacks .....                     | 3  |
| 3. System Hacking.....                       | 5  |
| 4. Enumeration.....                          | 6  |
| Types of Enumeration .....                   | 6  |
| 5. Password Cracking.....                    | 10 |
| 6. Privilege Escalation.....                 | 11 |
| 7. Executing Apps & Maintaining Access ..... | 12 |
| 8. Hiding Files & Covering Tracks.....       | 12 |
| Steganography.....                           | 13 |

### Social Engineering

- Social engineering is the act of **manipulating people into revealing confidential information or performing actions** that compromise security.
- Instead of attacking technical systems, attackers exploit human emotions such as trust, fear, curiosity, or urgency.
- **Importance:**
  - Social engineering is extremely dangerous because it targets the **weakest link in cybersecurity — humans**.
  - Even the strongest firewalls or encryption cannot protect an organization if an employee is tricked into sharing passwords or clicking malicious links.
  - It is widely used in phishing, fraud, identity theft, financial scams, and targeted corporate attacks.

#### Types of Social Engineering

1. **Human-Based Social Engineering:** Human-based techniques involve **direct interaction with people** to gain trust and extract information. Examples include:
  - **Impersonation:** Attacker pretends to be an employee, technician, manager, or delivery person to gain access to secure areas or data.
  - **Shoulder Surfing:** Observing someone's screen or keyboard to steal passwords or sensitive information.
  - **Dumpster Diving:** Searching through trash for discarded documents, passwords, or hardware.
  - **Tailgating / Piggybacking:** Following someone through a secure door by pretending to belong there.

These techniques rely heavily on human behavior and physical presence.

2. **Computer-Based Social Engineering:** Computer-based techniques use **digital channels** such as email, SMS, or social media to trick victims. Examples include:
  - **Phishing:** Fake emails designed to steal credentials or deliver malware.

- **Spear-Phishing:** Highly targeted phishing aimed at specific employees or executives using personalized information.
- **Vishing:** Voice phishing using fake calls from "banks" or "IT support."
- **Smishing:** SMS messages that lure victims into clicking malicious links.
- **Baiting:** Leaving infected USB drives or offering fake downloads that install malware.
- **Social Media Exploitation:** Creating fake profiles or gathering personal information to build trust.

These attacks are scalable and often the first step in larger cyberattacks.

### Common Targets

1. **Employees:** Attackers frequently target ordinary employees because they have login credentials and access to internal systems but may lack strong security awareness.
2. **Executives:** Executives are high-value targets because they can authorize financial transactions and access sensitive data. Spear-phishing and CEO fraud often focus on them.
3. **Vendors / Suppliers:** Third-party vendors may have trusted access to systems or networks. Compromising a vendor can indirectly compromise the main organization (supply chain attacks).
4. **Contractors:** Contractors often work temporarily and might not follow strict security policies. They can be exploited to gain physical or digital access.

### 7.4 Social Engineering Attack Lifecycle

1. **Research:** The attacker gathers information about the target — such as job roles, email patterns, habits, or organizational structure. This helps them craft believable attacks.
2. **Hook:** The attacker creates initial contact using a convincing message, call, or physical interaction. The goal is to gain trust or trigger an emotional response (fear, urgency, curiosity).
3. **Play:** This is the active exploitation phase. The attacker gets the victim to perform the desired action — such as sharing credentials, clicking a link, downloading a file, or granting access.
4. **Exit:** The attacker ends the interaction and removes traces. They may cover evidence or maintain backdoor access for future attacks.

## Defense Strategies

### 1. Awareness Training

- Awareness training teaches employees how social engineering attacks work and how to recognize suspicious behavior.
- It includes identifying phishing emails, avoiding unknown links or attachments, handling sensitive data safely, and understanding psychological manipulation tactics.
- Well-trained employees act as the first line of defense.

### 2. Verification Protocols

- Verification protocols ensure that sensitive actions are only performed after confirming the identity of the requester.
- This includes callback verification, multi-step approvals, and confirming instructions through official channels.
- For example, no financial transaction should be approved solely based on an email request.

### 3. Data Loss Prevention (DLP)

- DLP tools monitor and prevent unauthorized sharing or leakage of sensitive information.
- They can detect when employees attempt to email confidential data, upload files to cloud storage, or copy data to removable devices.

- DLP reduces the risk of insiders — mistakenly or intentionally — exposing critical information.

#### 4. Phishing Simulations

- Organizations perform controlled phishing tests to evaluate how employees react to fake phishing emails.
- These simulations measure awareness levels, identify weak departments, and help improve training.
- Repeated simulations build stronger resistance to real phishing attacks.

#### 5. Email and Web Filtering

- Email filters block malicious attachments, phishing messages, spoofed addresses, and spam before they reach users.
- Web filtering prevents access to malicious websites, fake login pages, and suspicious downloads.
- Together, these filters significantly reduce the number of social engineering attempts that reach employees.

#### 6. Strong Authentication

- Using multi-factor authentication (MFA) ensures that even if attackers steal passwords through phishing, they still cannot access accounts.
- Strong authentication combines something you know (password), something you have (OTP, token), or something you are (biometrics).
- This prevents unauthorized access and limits the impact of credential theft.

#### 7. Reporting & Incident Response Procedures

- Employees must know how to report suspicious emails, calls, or activity immediately.
- The security team should have a clear incident response plan to analyze the threat, contain damage, remove malware, and alert relevant teams.
- Quick reporting helps stop attacks before they spread.

#### 8. Zero-Trust Policies

- Zero trust assumes that **no user or device is automatically trusted**, even if inside the organization.
- Every request must be authenticated, authorized, and continuously monitored.
- This limits the damage from compromised accounts and prevents attackers from moving laterally across the network.

## Insider Attacks

An **insider threat** refers to any risk posed by individuals who already have authorized access to an organization's systems, data, or facilities. These insiders—such as employees, contractors, or partners—may intentionally cause harm or accidentally create vulnerabilities through negligence, misuse, or by having their accounts compromised. Because they operate from a position of trust, insider threats are often harder to detect and can cause significant damage.

## Types of Insider Threats

### 1. Malicious Insiders

- Malicious insiders intentionally misuse their authorized access to harm the organization.
- They may steal data, sabotage systems, leak confidential information, or assist external attackers.
- Their motive may be revenge, financial gain, or dissatisfaction with the organization. Because they already have access, these attacks can be extremely damaging.

### 2. Negligent Insiders

- Negligent insiders cause unintentional harm due to carelessness or lack of awareness.
- Examples include clicking phishing links, misconfiguring servers, losing laptops, or mishandling sensitive data.
- These insiders are not malicious, but their actions create serious security vulnerabilities.

### 3. Compromised Insiders

- A compromised insider is a legitimate employee whose device or credentials have been hacked by an attacker.
- The attacker then uses the insider's identity to move inside the network undetected.
- This type is hard to detect because activities appear to come from a trusted account.

## Common Insider Attack Techniques

1. **Data Theft:** Insiders may copy or transfer confidential data such as customer records, designs, pricing details, or intellectual property. They often use USB drives, email, cloud storage, or personal devices to steal data.
2. **Sabotage:** Sabotage involves intentionally damaging systems, deleting files, crashing servers, or injecting malware. Disgruntled employees or fired staff often attempt sabotage before leaving the organization.
3. **Privilege Misuse:** Insiders with higher access privileges may misuse them to access unauthorized data or systems. Examples include IT admins bypassing controls, finance employees accessing payroll data, or staff elevating privileges without approval.

## Detection & Monitoring

Detecting insider threats requires **continuous monitoring** of user activities and unusual behavior. Techniques include:

- Monitoring login patterns and detecting abnormal access times
- Tracking large file transfers, USB usage, or unusual downloads
- Using SIEM tools to analyze logs for suspicious actions
- Behavioral analytics (UEBA) to identify deviations from normal behaviour
- Alerts for privilege escalation, unauthorized access attempts, or accessing sensitive data without business need

Early detection helps prevent data loss and internal misuse.

## Prevention Strategies

1. **Access Control & PAM (Privileged Access Management):** Limit access to only what users need least privilege). PAM tools control and monitor admin-level accounts to prevent misuse. Just-in-time access and session recording help reduce risk.
2. **HR Screening & Behavioral Monitoring:** Conduct background checks during hiring and monitor behavioral red flags such as sudden dissatisfaction, unexplained overtime, or unusual access patterns. HR and security teams work together to detect risky employees early.

3. **Awareness Training:** Educate employees about phishing, secure data handling, reporting procedures, and company policies. This reduces negligent mistakes and builds a security-aware culture.
4. **Zero-Trust Architecture:** Zero trust removes implicit trust, even for internal users. Every access request must be verified, authenticated, and authorized. Micro-segmentation prevents insiders from moving freely across the network if one account is compromised.

### Case Examples

1. **Employee Stealing Data Before Resignation:** An employee planning to join a competitor copies sensitive project data using a USB drive. Lack of monitoring and unrestricted access allowed data theft without detection.
2. **Negligent Insider Causing Malware Infection:** A staff member opens a phishing email attachment, unknowingly installing ransomware on the system. This spreads across the network, causing downtime and financial loss.
3. **Compromised Credentials Used for Unauthorized Access:** An attacker steals an employee's VPN credentials through a phishing attack. Because the login looked legitimate, the attacker accessed internal resources for weeks before being detected.

## System Hacking

**System Hacking** is the phase of penetration testing or real-world attacking where an individual attempts to compromise a target system (like a server or workstation) to gain access to resources.

### System Hacking Phases

These four phases describe the typical sequence of actions an attacker takes once they have identified a target and a vulnerability.

1. **Gaining Access:**
  - **Goal:** To enter the network or compromise a system for the first time, often as a low-privilege user.
  - **Methods:** Exploiting a vulnerability (e.g., buffer overflow, unpatched software), cracking a password, or using social engineering (e.g., phishing).
  - **Result:** A **foothold** on the system (e.g., a non-administrator command shell).
2. **Escalating Privileges:**
  - **Goal:** To move from the initial low-level access to a higher-level account, such as root (Linux) or System/Administrator (Windows).
  - **Methods:** Exploiting kernel or operating system vulnerabilities, searching for misconfigured services, or leveraging stored credentials.
  - **Result:** **Full administrative control** over the compromised system.
3. **Maintaining Access:**
  - **Goal:** To ensure the attacker can return to the compromised system later, even if the initial vulnerability is patched or the system is rebooted.
  - **Methods:** Installing **backdoors** (hidden ways to log in), creating hidden user accounts, or installing **rootkits** (stealthy tools to hide malicious files and processes).
4. **Covering Tracks (Clearing Logs):**
  - **Goal:** To hide all evidence of the intrusion to prevent detection by defensive tools (like SIEM) or forensic investigators.
  - **Methods:** **Clearing/editing system logs** (Windows Event Viewer, Linux /var/log files), modifying file timestamps, and using anti-forensics tools.

# Enumeration

**Enumeration** is the critical post-scanning process where the attacker establishes an active connection to the target system(s) and uses focused queries to extract detailed information about users, groups, shares, and network resources.

**Purpose:** The goal is to gather specific, high-value information that can directly lead to system compromise or privilege escalation. This information includes:

- Usernames and Group names.
- Network shares and services.
- System banners and configurations.

## Common Enumeration Protocols

Attackers often target specific services that are configured to leak information:

- **NetBIOS (Network Basic Input/Output System):** Used for name resolution and service discovery on older Windows networks.
- **SNMP (Simple Network Management Protocol):** Used to monitor and manage network devices.
- **LDAP (Lightweight Directory Access Protocol):** Used to query directory services (like Active Directory) for user/group details.
- **SMTP (Simple Mail Transfer Protocol):** Email server protocol that can leak valid usernames via commands like VRFY and EXPN.
- **NTP (Network Time Protocol):** Used to synchronize system clocks; can sometimes leak host information.

## NetBIOS Enumeration

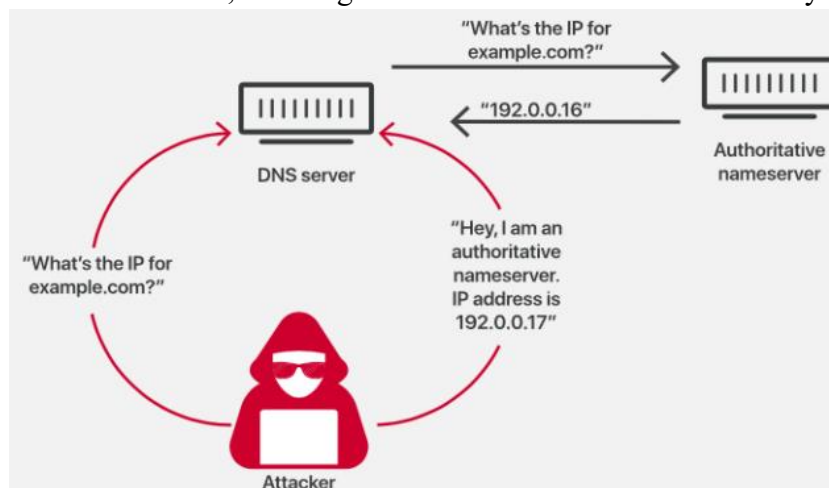
**NetBIOS (Network Basic Input/Output System)** is a legacy protocol that provides name resolution and session services for applications running on a local area network (LAN), primarily used by older Windows systems.

- **Target:** Windows systems, often over **TCP/UDP ports 137 and 139**.
- **Purpose:** To retrieve a list of computer names, domains, workgroups, and shared resources (including hidden shares).
- **Technique:** An attacker sends NetBIOS queries (like the **nbtstat** command) to the target to request the NetBIOS Name Table, which often lists system roles and user information.
- **Vulnerability:** Systems configured to respond to NetBIOS name queries from any source without proper filtering.

## Types of Enumeration

1. **Null Session Enumeration:** A **Null Session** is a connection established to the **IPC\$** (Interprocess Communication) share on a Windows machine using a **blank (null)** username and password.
  - **Target:** Primarily older Windows NT, 2000, and sometimes XP servers.
  - **Purpose:** To access detailed information from the **Security Account Manager (SAM)**, including lists of:
    - Usernames and Security Identifiers (SIDs).
    - Group names and membership.
    - Network shares.
  - **Technique:** The attacker attempts to connect to the target using a specific command (e.g., `net use \\TargetIP\IPC$ "" /user:""`) and then uses utilities to query the system information.

- **Vulnerability:** Older Windows operating systems allowed unauthenticated users to establish these sessions, which Microsoft later patched in modern OS versions.
2. **DNS Enumeration using Zone Transfer:** DNS (Domain Name System) translates human-readable domain names into IP addresses. A **Zone Transfer** is a crucial mechanism that can leak the entire network map.
- **Target:** DNS servers (**TCP port 53**).
  - **Purpose:** To obtain a **complete list of all hosts, servers, and subdomains** within a DNS zone (domain), effectively mapping the organization's entire external and internal naming scheme.
  - **Technique:** An attacker requests an **AXFR** (Asynchronous Full Transfer Zone) query from the target DNS server, pretending to be a legitimate secondary DNS server.
  - **Vulnerability:** Primary DNS servers that are configured to allow zone transfers to **any host** instead of restricting them only to authorized secondary DNS servers.
  - **Countermeasure:** Configure the DNS server to **restrict zone transfers** to specific, approved IP addresses of secondary DNS servers.
  - **DNS cache poisoning**(image below) is an attack where an attacker injects **false DNS records** into a DNS server's cache. As a result, when users request a legitimate domain, the DNS server responds with the **attacker's fake IP address** instead of the real one. This redirects users to malicious websites, enabling credential theft or malware delivery.



3. **SNMP Enumeration:** SNMP (Simple Network Management Protocol) is used by administrators to monitor and manage network devices (routers, switches, servers). If configured insecurely, it leaks vast amounts of system information.
- **Target:** Any device running the SNMP service (common on network hardware).
  - **Purpose:** To download the device's **Management Information Base (MIB)**, which contains a hierarchical structure of variables, including:
    - System uptime and configuration.
    - User accounts and credentials (if poorly configured).
    - Network interface details (traffic, errors).
  - **Vulnerability:** The use of default or easily guessed **Community Strings** (passwords).
    - **public:** Default read-only access string.
    - **private:** Default read/write access string (highly dangerous).
  - **SNMP Versions:** Attackers primarily target **SNMPv1** and **SNMPv2c**, which transmit community strings in **clear text**. **SNMPv3** is more secure as it adds encryption and authentication.

4. **NTP Enumeration:** NTP (Network Time Protocol) is used to synchronize the clocks of computer systems over a network. While essential for security (timing is critical for logging and encryption), it can be exploited for enumeration.
- **Target:** NTP servers (**UDP port 123**).
  - **Purpose:** To retrieve a list of hosts that the NTP server has communicated with or is synchronizing time with. This helps an attacker **map the internal network structure** and identify active hosts.
  - **Technique:** Using commands like **monlist** (in older NTP versions) which returns a list of the last 600 hosts that contacted the server.
  - **Vulnerability:** Misconfigured NTP servers that respond to monitoring commands from unauthorized external sources.
  - **Countermeasure:** Disable or restrict the monlist command; upgrade to modern, secured NTP versions; and implement **firewall rules** to restrict NTP traffic to internal time servers only.
5. **SMTP Enumeration:** SMTP (Simple Mail Transfer Protocol) is used for sending emails. Mail servers often inadvertently reveal valid usernames.
- **Target:** SMTP servers (**TCP port 25**).
  - **Purpose:** To confirm **valid usernames** on the target mail server. Valid usernames are essential for dictionary attacks and spear phishing campaigns.
  - **Technique:** Using SMTP commands like:
    - **VERFY (Verify):** Asks the server if a user is valid (deprecated, but still found).
    - **EXPN (Expand):** Asks the server to expand a mailing list, revealing the valid usernames in that list.
    - **RCPT TO (Recipient To):** Used during the mail-sending process; the server's response indicates if the recipient address is valid.
  - **Vulnerability:** Servers that respond with distinct error codes (e.g., "User valid" vs. "User not found") to these commands.
  - **Countermeasure:** Configure the mail server to **disable or suppress responses** to VRFY and EXPN commands. Treat all invalid users with the same generic error code.
6. **IPsec Enumeration:** IPsec (Internet Protocol Security) is a suite of protocols used to secure IP communications, commonly used for **VPNs** (Virtual Private Networks).
- **Target:** IPsec VPN gateways (often UDP ports 500/4500).
  - **Purpose:** To identify whether the VPN is using strong authentication mechanisms, which part of the network it protects, and if it's susceptible to brute-forcing.
  - **Technique:** Using tools like **IKE-Scan** (for IKE, the key exchange protocol in IPsec) to fingerprint the VPN device and determine the security policies (e.g., encryption algorithms, hash algorithms) it supports.
  - **Vulnerability:** Weak or common **Pre-Shared Keys (PSKs)** used for authentication, which can be brute-forced or dictionary-attacked once the policy is known.
  - **Countermeasure:** Use **strong, complex PSKs** (or, better yet, switch to certificate-based authentication) and implement strict firewall rules to limit access to the VPN gateway.
7. **VoIP (Voice over IP) Enumeration:** VoIP systems (like corporate phone systems) use protocols like SIP (Session Initiation Protocol) and **H.323**.
- **Target:** VoIP/SIP servers and endpoints (often **UDP/TCP port 5060/5061**).
  - **Purpose:** To identify **valid extensions and usernames** within the internal phone system. This information is used for denial-of-service (DoS) attacks, toll fraud, or eavesdropping.

- **Technique:** Sending SIP REGISTER or INVITE requests with known default passwords or common usernames/extensions and analyzing the server's error responses to confirm validity.
  - **Vulnerability:** Using sequential or guessable extension numbers (e.g., 1001, 1002, 1003) and weak default SIP passwords.
  - **Countermeasure:** Configure SIP servers to require **strong passwords** for endpoints and implement **rate limiting** to prevent rapid-fire requests against the SIP registrar.
8. **RPC Enumeration:** RPC (Remote Procedure Call) is a protocol that allows a program on one computer to execute code on a remote computer. It is a fundamental mechanism in Windows domains.
- **Target:** Windows systems (TCP/UDP ports 135, 139, 445).
  - **Purpose:** To discover the remote services and applications that are available for external execution, aiding in mapping the attack surface.
  - **Technique:** Using tools to query the **RPC Endpoint Mapper** (port 135) to find out which dynamic ports are being used by specific RPC services. This can lead to the discovery of sensitive services like the **SAM** (Security Account Manager) or **LSA** (Local Security Authority).
  - **Vulnerability:** Overly permissive firewall rules that allow access to the RPC ports from unauthorized segments of the network.
  - **Countermeasure:** Restrict access to ports 135, 139, and 445 via the firewall to trusted internal hosts only, and use **Group Policy** to limit which accounts can perform remote RPC operations.
9. **Unix/Linux User Enumeration:** This focuses on obtaining user lists from Unix or Linux systems, often leveraging common network services.
- **Target:** Unix/Linux systems (often over **SSH/FTP/finger** services).
  - **Purpose:** To retrieve a list of valid local and system accounts for brute-forcing attacks.
  - **Technique:**
    - **Finger Protocol (Port 79):** If enabled, this legacy service can return a list of users currently logged into the system.
    - **SSH (Port 22):** Using tools to determine the existence of a username by observing the server's response time difference between an invalid user login attempt and a valid user login attempt.
    - **FTP (Port 21):** Attempting to log in with a username and receiving different failure messages depending on whether the account exists or the password was merely wrong.
  - **Vulnerability:** Enabling verbose error messages on login attempts or enabling legacy services like the Finger protocol.
  - **Countermeasure:** **Disable the Finger protocol;** use **generic failure messages** for all failed login attempts (regardless of whether the username was valid); and use **two-factor authentication (2FA)** for SSH access.

## Countermeasures

Preventing enumeration is a core defensive strategy in hardening a system:

1. **Block/Filter Ports:** Block or restrict external access to ports associated with enumeration (e.g., TCP/UDP 137, 139, UDP 161/162).
2. **Disable Unused Services:** Disable NetBIOS and other legacy services (like SNMP) if they are not strictly required.
3. **Secure Protocols:** If SNMP is needed, use **SNMPv3** which supports authentication and encryption, and change the default community strings.

4. **Use Strong Authentication:** Enforce strong passwords and limit access to domain services (like LDAP) only to authorized users/systems.
5. **Apply Patches:** Ensure the operating system and services are fully patched to eliminate vulnerabilities that allow for unauthorized information disclosure.

## Password Cracking

### Password Storage & Hashing

- Passwords are not stored as plain text. Instead, systems store **hashed versions** using algorithms like SHA-256, bcrypt, or PBKDF2.
- A hash is a one-way function, meaning the password cannot be easily reversed from the hash.
- However, if attackers obtain the hashed password database, they can attempt to crack the hashes using various techniques as follows:

#### 1. Dictionary Attacks

- Dictionary attacks try passwords from a predefined list of common or likely passwords (e.g., “123456”, “Password@123”).
- They are fast but limited to words present in the dictionary list.

#### 2. Brute-Force Attacks

- Brute-force attacks try **every possible combination** of characters until the correct password is found.
- They guarantee success but take a long time, especially if the password is long and complex.

#### 3. Hybrid Attacks

- Hybrid attacks combine dictionary and brute-force methods.
- For example, starting with dictionary words and then adding numbers or symbols at the end, like “password123”.

#### 4. Rainbow Tables

- Rainbow tables are large, precomputed databases of hash-to-password mappings.
- Instead of hashing every guess, attackers look up matches quickly.
- They are extremely fast but require huge storage.
- Modern systems use **salting** (adding random data to passwords), which makes rainbow tables ineffective.

#### 5. Social Engineering-Based Attacks

- Attackers trick users into revealing their passwords through phishing, fake login pages, phone calls, or impersonation.
- Since humans often reuse weak passwords, social engineering is often more effective than technical cracking.

### Countermeasures (MFA, Policies, Lockout)

- **MFA (Multi-Factor Authentication):** Even if attackers crack a password, they cannot access the account without a second factor.
- **Strong Password Policies:** Enforce minimum length, complexity, and periodic changes.

- **Account Lockout:** Locks the account after repeated failed attempts, stopping brute-force attacks.
- **Salting & hashing:** Prevents rainbow table attacks.
- **User training:** Reduces risk of phishing-based password theft.

## Privilege Escalation

**Privilege Escalation** is the act of exploiting a flaw, design weakness, or configuration oversight in an operating system or application to gain elevated access to resources that are normally restricted.

### Vertical & Horizontal Escalation

- **Vertical Privilege Escalation (Elevation):** The attacker gains higher-level permissions than their current account (e.g., moving from a standard user to an **Administrator/Root** account). This is the most common goal.
- **Horizontal Privilege Escalation:** The attacker gains the privileges of another user at the **same privilege level** (e.g., moving from User A's standard account to User B's standard account to access User B's files).

| Method                | Description                                                                                                                  | Example                                                                                       |
|-----------------------|------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|
| Software Exploits     | Targeting vulnerabilities in the OS kernel or third-party applications to gain system-level access.                          | A buffer overflow in a service running with system privileges.                                |
| Misconfiguration      | Exploiting poorly configured systems or services.                                                                            | A service running with excessive permissions (e.g., running a web server as the 'root' user). |
| Unpatched Systems     | Leveraging well-known vulnerabilities for which a patch exists but has not been applied.                                     | Using a public exploit for a known Windows kernel flaw.                                       |
| Weak File Permissions | The attacker modifies a configuration file or script to point to malicious code that runs when executed by an administrator. | A configuration file being writable by all users (e.g., /etc/passwd).                         |

### Defense

- **Principle of Least Privilege (PoLP):** This is the **most fundamental defense**. Users and applications should only be given the **minimum permissions necessary** to perform their specific job functions, limiting the potential damage if an account is compromised.
- **Patching and Updates:** **Regularly applying security patches** to the OS and all applications to eliminate known vulnerabilities before they can be exploited.
- **Secure Configuration:** Running services with the **lowest necessary privilege level** and ensuring secure file/directory permissions.
- **Vulnerability Scanning:** Proactive scanning to identify and correct misconfigurations and known weaknesses.

## Executing Apps & Maintaining Access

Once an attacker has successfully gained access and escalated privileges on a system, the next goal is to ensure long-term, stealthy control.

### Backdoors & Trojans (Awareness)

- **Backdoor:** A secret method or utility placed by the attacker to bypass normal authentication and security checks.<sup>1</sup> It ensures the attacker can **re-enter the system** easily later.
  - *Mechanism:* Often achieved by creating a **hidden user account**, modifying a legitimate system file, or installing a service that listens on a non-standard port.
- **Trojan (Trojan Horse):** Malicious software disguised as a legitimate or desirable program.<sup>2</sup> It serves as the delivery mechanism for the initial intrusion or for the backdoors.<sup>3</sup>
  - *Awareness:* Users must be trained to **verify the source and integrity** of all software they download and execute, as a Trojan relies entirely on user deception.<sup>4</sup>

### Legal Restrictions

- **Due Diligence:** In the real world, the installation of tools, backdoors, or Trojans is strictly **illegal** and constitutes unauthorized access and damage.
- **Penetration Testing (Ethical Hacking):** Within a security assessment, the installation of testing tools (like a reverse shell) is only permissible with **explicit, written authorization** from the client (the **Rules of Engagement**) and must be immediately removed upon completion. Failure to adhere to the scope leads to **liability and legal consequences**.

### Monitoring Unauthorized Processes

- **Attacker's Goal:** An attacker needs to monitor their own unauthorized processes to ensure they remain running and undetected.
- **Defender's Role (Countermeasure):** Defenders must proactively monitor system processes for anomalies:
  - **Unknown Processes:** Identifying services or executables that are not part of the standard operating system build.
  - **High CPU/Network Usage:** Malware and backdoors often consume excessive resources.<sup>5</sup>
  - **Unusual Parent/Child Relationships:** Observing a legitimate process (like Word) launching a command shell, which is highly suspicious.
  - **Tools:** Using tools like **Task Manager, Process Explorer, and Endpoint Detection and Response (EDR)** systems for continuous monitoring.

## Hiding Files & Covering Tracks

The final phase aims to eliminate all evidence of the intrusion to prevent discovery and subsequent eradication.

### File Hiding Basics

Attackers employ several techniques to hide their tools, logs, and backdoors:

- **Hidden File Attributes:** Simply setting the hidden file attribute on Windows or preceding a filename with a dot (.) in Linux/Unix (e.g., `.hidden_file`).

- **Alternate Data Streams (ADS):** A feature of the NTFS file system (Windows) that allows data to be hidden inside an existing, visible file (like an image) without changing the file's size or appearance.<sup>8</sup> This data is not visible through standard directory listings.
- **Rootkits:** Sophisticated toolsets installed at the kernel level that actively modify the OS to hide malicious processes, files, and registry keys from detection utilities.

## Steganography

**Steganography** is the art of **concealing the existence** of a message, file, image, or video within another, seemingly innocuous message or file.<sup>9</sup> Unlike encryption (where the message is scrambled but its existence is known), steganography makes the communication itself appear nonexistent.

1. **Concealed Data Mediums:** Any file format with high redundancy or complexity can be used as a **cover medium**.

| Medium | Description                                                                                                                  | Example                                                                           |
|--------|------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| Image  | Hiding data in the <b>Least Significant Bit (LSB)</b> of each pixel's color value, resulting in imperceptible color changes. | Hiding a malicious script within a picture of a cat.                              |
| Audio  | Hiding data in inaudible frequency ranges or by subtly altering the least significant parts of the audio data.               | Hiding a password file within a normal MP3 song.                                  |
| Video  | Hiding data within the video frame or the audio track, or manipulating unused space within the video container format.       | Hiding a backdoor within a 5-minute company training video.                       |
| Text   | <b>Manipulating white space, character spacing, or using synonyms.</b>                                                       | <b>Hiding a message by slightly adjusting the spacing between words or lines.</b> |

2. **Least Significant Bit (LSB) Insertion:** This is the most common steganography technique, particularly for images. Digital images are composed of pixels, and each pixel's color is defined by several bits. The LSB contributes the least to the overall color. The attacker replaces the LSB of select color bits with the secret message's bits. Example

Original Pixel Bit Value: 10101010

Secret Message Bit: 1

New Pixel Bit Value: 10101011

## Countermeasures: Steganalysis

**Steganalysis** is the process of detecting the presence of hidden information concealed using steganography. It requires specialized tools and analytical techniques.

1. **Statistical Analysis:** Tools analyze the statistical properties of a file (like the distribution of color values in an image or sound levels in an audio file). If a message has been inserted using LSB, it often creates slight, non-random changes in these statistical patterns that can be detected.
2. **Visual and Auditory Inspection:** While hard to do manually, software can highlight areas where small color or sound changes are clustered.
3. **File Comparison:** Comparing a suspected file against a known, clean, original version of the file (if available) to identify data changes.
4. **Anomaly Detection:** Detecting discrepancies in file size or format headers that may result from embedding a hidden message.

### Log Clearing vs. Defensive Logging

| Aspect        | Log Clearing (Attacker Action)                                                                             | Defensive Logging (Defender Countermeasure)                                                                                           |
|---------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| Goal          | <b>Eliminate the trail</b> of the intrusion to prevent detection and forensic investigation.               | <b>Ensure a reliable, complete record</b> of all system and user activities for security monitoring and audit.                        |
| Mechanism     | Deleting or editing specific entries within local event logs (e.g., Windows Event Viewer, Linux /var/log). | <b>Centralizing logs</b> in real-time to a secure, remote server (SIEM).                                                              |
| Impact        | Hinders detection, makes <b>attribution</b> (who did it) nearly impossible, and prevents system recovery.  | Enables <b>real-time monitoring</b> for anomalies and provides the necessary <b>digital evidence</b> for post-incident analysis.      |
| Best Practice | <i>(N/A - Illegal)</i>                                                                                     | Use <b>Write-Once, Read-Many (WORM)</b> media or <b>immutable storage</b> to ensure logs cannot be deleted or altered by an attacker. |